

THE GENERAL ASSEMBLY OF PENNSYLVANIA

HOUSE BILL

No. 78 Session of
2025

INTRODUCED BY NEILSON, SCIALABBA, HOWARD, MENTZER, LEADBETER,
SANCHEZ, HILL-EVANS, GIRAL, FRANKEL, KHAN, ARMANINI, WARREN,
FREEMAN, OTTEN, ZIMMERMAN, GILLEN, CIRESI, T. DAVIS AND
K.HARRIS, JANUARY 14, 2025

AS AMENDED ON SECOND CONSIDERATION, HOUSE OF REPRESENTATIVES,
APRIL 23, 2025

AN ACT

1 Providing for consumer data privacy, for duties of controllers
2 and for duties of processors; and imposing penalties.

3 The General Assembly of the Commonwealth of Pennsylvania
4 hereby enacts as follows:

5 Section 1. Short title.

6 This act shall be known and may be cited as the Consumer Data
7 Privacy Act.

8 Section 2. Definitions.

9 The following words and phrases when used in this act shall
10 have the meanings given to them in this section unless the
11 context clearly indicates otherwise:

12 "Affiliate." A legal entity that shares common branding with
13 another legal entity or controls, is controlled by or is under
14 common control with another legal entity.

15 "Biometric data." Data generated by automatic measurements
16 of an individual's biological characteristics, including

1 fingerprints, voiceprints, eye retinas, irises or other unique
2 biological patterns or characteristics that are used to identify
3 a specific individual. The term does not include a digital or
4 physical photograph, an audio or video recording or any data
5 generated from a digital or physical photograph or an audio or
6 video recording. The term does not include information captured
7 and converted to a mathematical representation, including a
8 numeric string or similar method that cannot be used to recreate
9 the data captured or converted to create the mathematical
10 representation.

11 "Business associate." As defined in 45 CFR 160.103 (relating
12 to definitions)

13 "Child." As defined in 15 U.S.C. § 6501 (relating to
14 definitions).

15 "Common branding." A shared name, servicemark or trademark.

16 "Consent." A clear affirmative act signifying a consumer's
17 freely given, specific, informed and unambiguous agreement to
18 allow the processing of personal data relating to the consumer.
19 The term includes a written statement, including by electronic
20 means, or any other unambiguous affirmative action specified in
21 this definition. The term does not include acceptance of general
22 or broad terms of use or a similar document that contains
23 descriptions of personal data processing along with other
24 unrelated information, hovering over, muting, pausing or closing
25 a given piece of content or an agreement obtained through the
26 use of dark patterns.

27 "Consumer." An individual who is a resident of this
28 Commonwealth. The term does not include an individual acting in
29 a commercial or employment context or as an employee, owner,
30 director, officer or contractor of a company, partnership, sole

1 proprietorship, nonprofit or government agency whose
2 communications or transactions with a controller occur solely
3 within the context of that individual's role with the company,
4 partnership, sole proprietorship, nonprofit or government
5 agency.

6 "Control." Any of the following:

7 (1) Ownership of or the power to vote on more than 50%
8 of the outstanding shares of any class of voting security of
9 a controller.

10 (2) Control in any manner over the election of a
11 majority of the directors or over the individuals exercising
12 similar functions.

13 (3) The power to exercise a controlling influence over
14 the management of a company.

15 "Controller." As follows:

16 (1) A sole proprietorship, partnership, limited
17 liability company, corporation, association or other legal
18 entity that meets all of the following criteria:

19 (i) Is organized or operated for the profit or
20 financial benefit of its shareholders or other owners.

21 (ii) Alone or jointly with others, determines the
22 purposes and means of the processing of consumers'
23 personal information.

24 (iii) Does business in this Commonwealth.

25 (iv) Satisfies any of the following thresholds:

26 (A) Has annual gross revenues in excess of
27 \$10,000,000.

28 (B) Alone or in combination, annually buys or
29 receives, sells or shares for commercial purposes,
30 alone or in combination, the personal information of

1 at least 50,000 consumers, households or devices.

2 (C) Derives at least 50% of annual revenues from
3 selling consumers' personal information.

4 (2) An entity that controls a sole proprietorship,
5 partnership, limited liability company, corporation,
6 association or other legal entity under paragraph (1) or
7 shares common branding with the sole proprietorship,
8 partnership, limited liability company, corporation,
9 association or other legal entity.

10 "Covered entity." As defined in 45 CFR 160.103.

11 "Dark pattern." A user interface designed or manipulated
12 with the substantial effect of subverting or impairing user
13 autonomy, decision making or choice, including a practice the
14 Federal Trade Commission refers to as a dark pattern.

15 "Decisions that produce legal or similarly significant
16 effects concerning the consumer." Decisions made by a
17 controller that result in the provision or denial by the
18 controller of financial or lending services, housing, insurance,
19 education enrollment or opportunity, criminal justice,
20 employment opportunities, health care services or access to
21 essential goods or services.

22 "De-identified data." Data that cannot reasonably be used to
23 infer information about, or otherwise be linked to, an
24 identified or identifiable individual or a device linked to the
25 individual, if the controller that possesses the data complies
26 with the following criteria:

27 (1) Takes reasonable measures to ensure that the data
28 cannot be associated with an individual.

29 (2) Publicly commits to process the data only in a de-
30 identified fashion and not attempt to re-identify the data.

(3) Contractually obligates a recipient of the data to satisfy the criteria specified under paragraphs (1) and (2).

"HIPAA." The Health Insurance Portability and Accountability Act of 1996 (Public Law 104-191, 110 Stat. 1936).

"Identified or identifiable individual." An individual who can be readily identified, directly or indirectly.

"Institution of higher education." As defined in section 118(c) of the act of March 10, 1949 (P.L.30, No.14), known as the Public School Code of 1949.

"Nonprofit organization." An organization that is exempt from taxation under 26 U.S.C. § 501(c)(3), (4), (6) or (12) (relating to exemption from tax on corporations, certain trusts, etc.).

"Personal data." As follows:

(1) Any information that is linked or reasonably linkable to an identified or identifiable individual.

(2) The term does not include publicly available information, de-identified data or biometric data captured and converted to a mathematical representation.

"Precise geolocation data." Information derived from technology, including global positioning system level latitude and longitude coordinates or other mechanisms, that directly identifies the specific location of an individual with precision and accuracy within a radius of 1,750 feet. The term does not include the content of communications, or any data generated by or connected to advanced utility metering infrastructure systems or equipment for use by a utility.

"Process" or "processing." An operation or set of operations performed, whether by manual or automated means, on personal data or on sets of personal data, including the collection, use,

1 storage, disclosure, analysis, deletion or modification of
2 personal data.

3 "Processing activities that present a heightened risk of harm
4 to a consumer." The term includes any of the following:

5 (1) The processing of personal data for the purpose of
6 targeted advertising.

7 (2) The sale of personal data.

8 (3) The processing of personal data for the purpose of
9 profiling if the profiling presents a reasonably foreseeable
10 risk of any of the following:

11 (i) Unfair or deceptive treatment of, or an unlawful
12 disparate impact on, a consumer.

13 (ii) Financial, physical or reputational injury to a
14 consumer.

15 (iii) A physical or other intrusion upon the
16 solitude or seclusion of a consumer or the private
17 affairs or concerns of a consumer where the intrusion
18 would be offensive to a reasonable person.

19 (iv) Any other substantial injury to a consumer.

20 (4) The processing of sensitive data.

21 "Processor." An individual who, or legal entity that,
22 processes personal data on behalf of a controller.

23 "Profiling." Any form of automated processing performed on
24 personal data to evaluate, analyze or predict personal aspects
25 related to an identified or identifiable individual's economic
26 situation, health, personal preferences, interests, reliability,
27 behavior, location or movements.

28 "Protected health information." As defined in 45 CFR
29 160.103.

30 "Pseudonymous data." Personal data that cannot be attributed

1 to a specific individual without the use of additional
2 information if the additional information is kept separately and
3 is subject to appropriate technical and organizational measures
4 to ensure that the personal data is not attributed to an
5 identified or identifiable individual.

6 "Publicly available information."

7 Information that:

8 (1) is lawfully available through Federal, State or
9 municipal records or widely distributed media; or

10 (2) a controller has a reasonable basis to believe a
11 consumer has lawfully made available to the general public.

12 "Sale of personal data." The exchange of personal data for
13 monetary or other valuable consideration by a controller to a
14 third party. The term does not include any of the following:

15 (1) The disclosure of personal data to a processor that
16 processes the personal data on behalf of the controller.

17 (2) The disclosure of personal data to a third party for
18 the purpose of providing a product or service requested by a
19 consumer.

20 (3) The disclosure or transfer of personal data to an
21 affiliate of the controller.

22 (4) The disclosure of personal data when a consumer
23 directs the controller to disclose the personal data or
24 intentionally uses the controller to interact with a third
25 party.

26 (5) The disclosure of personal data that a consumer:

27 (i) intentionally made available to the general
28 public via a channel of mass media; and

29 (ii) did not restrict to a specific audience.

30 (6) The disclosure or transfer of personal data to a

1 third party as an asset that is part of a merger,
2 acquisition, bankruptcy or other transaction or a proposed
3 merger, acquisition, bankruptcy or other transaction, in
4 which the third party assumes control of all or part of the
5 controller's assets.

6 ~~"Sensitive data." Personal data that includes data revealing~~ <--
7 ~~any of the following:~~

- 8 ~~(1) A racial or ethnic origin.~~
- 9 ~~(2) Religious beliefs.~~
- 10 ~~(3) Mental or physical health condition or diagnosis.~~
- 11 ~~(4) Sex life or sexual orientation.~~
- 12 ~~(5) Citizenship or immigration status.~~
- 13 ~~(6) The processing of genetic or biometric data for the~~
14 ~~purpose of uniquely identifying an individual.~~
- 15 ~~(7) Personal data collected from a known child.~~
- 16 ~~(8) Precise geolocation data.~~

17 "SENSITIVE DATA." AS FOLLOWS:

<--

18 (1) PERSONAL DATA THAT INCLUDES DATA REVEALING ANY OF
19 THE FOLLOWING:

- 20 (I) A RACIAL OR ETHNIC ORIGIN.
- 21 (II) RELIGIOUS BELIEFS.
- 22 (III) MENTAL OR PHYSICAL HEALTH CONDITION OR
23 DIAGNOSIS.
- 24 (IV) SEX LIFE OR SEXUAL ORIENTATION.
- 25 (V) CITIZENSHIP OR IMMIGRATION STATUS.
- 26 (VI) THE PROCESSING OF GENETIC OR BIOMETRIC DATA FOR
27 THE PURPOSE OF UNIQUELY IDENTIFYING AN INDIVIDUAL.
- 28 (VII) PERSONAL DATA COLLECTED FROM A KNOWN CHILD.
- 29 (VIII) PRECISE GEOLOCATION DATA.
- 30 (IX) SOCIAL SECURITY NUMBER.

(X) DRIVER'S LICENSE NUMBER OR A STATE IDENTIFICATION CARD NUMBER ISSUED IN LIEU OF A DRIVER'S LICENSE.

(XI) FINANCIAL ACCOUNT NUMBER, CREDIT OR DEBIT CARD NUMBER, IN COMBINATION WITH ANY REQUIRED SECURITY CODE, ACCESS CODE OR PASSWORD THAT WOULD PERMIT ACCESS TO AN INDIVIDUAL'S FINANCIAL ACCOUNT.

(2) THE TERM DOES NOT INCLUDE PUBLICLY AVAILABLE INFORMATION THAT IS LAWFULLY MADE AVAILABLE TO THE GENERAL PUBLIC FROM FEDERAL, STATE OR LOCAL GOVERNMENT RECORDS OR WIDELY DISTRIBUTED MEDIA.

"Targeted advertising." Displaying advertisements to a consumer if the advertisement is selected based on personal data obtained or inferred from the consumer's activities over time and across nonaffiliated Internet websites or online applications to predict the consumer's preferences or interests. The term does not include any of the following:

(1) Advertisements based on activities within a controller's own Internet websites or online applications.

(2) Advertisements based on the context of a consumer's current search query, visit to an Internet website or online application.

(3) Advertisements directed to a consumer in response to the consumer's request for information or feedback.

(4) Processing personal data solely to measure or report advertising frequency, performance or reach.

"Third party." An individual or legal entity, including a public authority, agency or body, other than a consumer, controller or processor or an affiliate of the processor or the controller.

1 "Trade secret." As defined in 12 Pa.C.S. § 5302 (relating to
2 definitions).

3 Section 3. Consumer data privacy.

4 (a) Rights of consumers.--A consumer shall have the right to
5 do the following:

6 (1) Confirm whether or not a controller is processing or
7 accessing the consumer's personal data, unless the
8 confirmation or access would require the controller to reveal
9 a trade secret.

10 (2) Correct inaccuracies in the consumer's personal
11 data, taking into account the nature of the personal data and
12 the purposes of the processing of the consumer's personal
13 data.

14 (3) Delete personal data provided by or obtained about
15 the consumer.

16 (4) Obtain a copy of the consumer's personal data
17 processed by a controller in a portable and, to the extent
18 technically feasible, readily usable format that allows the
19 consumer to transmit the data to another controller without
20 hindrance, where the processing is carried out by automated
21 means in a manner that would disclose the controller's trade
22 secrets.

23 (5) Opt out of the processing of the consumer's personal
24 data for the purpose of any of the following:

25 (i) Targeted advertising.

26 (ii) The sale of personal data, except as provided
27 under section 5(b).

28 (iii) Profiling in furtherance of solely automated
29 decisions that produce legal or similarly significant
30 effects concerning the consumer.

1 (b) Exercise of rights.--A consumer may exercise the rights
2 under subsection (a) by a secure and reliable means established
3 by a controller and described to the consumer in the
4 controller's privacy notice. A consumer may designate an
5 authorized agent in accordance with section 4 to exercise the
6 consumer's right under subsection (a)(5) to opt out of the
7 processing of the consumer's personal data on behalf of the
8 consumer. For processing personal data of a known child, the
9 parent or legal guardian may exercise the consumer's rights
10 under subsection (a) on the child's behalf. For processing
11 personal data concerning a consumer subject to a guardianship,
12 conservatorship or other protective arrangement, the guardian or
13 the conservator of the consumer may exercise the consumer's
14 rights under subsection (a) on the consumer's behalf.

15 (c) Compliance.--Except as otherwise provided in this act, a
16 controller shall comply with a request by a consumer to exercise
17 the consumer's rights under subsection (a) as follows:

18 (1) The controller shall respond to the consumer without
19 undue delay, but no later than 45 days after receipt of the
20 request. The controller may extend the response period under
21 this paragraph by an additional 45 days when reasonably
22 necessary, considering the complexity and number of the
23 consumer's requests, if the controller informs the consumer
24 of the extension within the initial 45-day response period
25 and the reason for the extension.

26 (2) If the controller declines to take action regarding
27 the consumer's request, the controller shall inform the
28 consumer without undue delay, but no later than 45 days after
29 receipt of the request, of the justification for declining to
30 take action and instructions for how to appeal the decision.

1 (3) Information provided in response to consumer
2 requests shall be provided by the controller, free of charge,
3 once per consumer during a 12-month period. If a request from
4 a consumer is manifestly unfounded, excessive or repetitive,
5 the controller may charge the consumer a reasonable fee to
6 cover the administrative costs of complying with the request
7 or decline to act on the request. The controller bears the
8 burden of demonstrating the manifestly unfounded, excessive
9 or repetitive nature of the request.

10 (4) If a controller is unable to authenticate a request
11 to exercise a right afforded under subsection (a)(1), (2),
12 (3) or (4) using commercially reasonable efforts, the
13 controller shall not be required to comply with a request
14 under this subsection and shall provide notice to the
15 consumer that the controller is unable to authenticate the
16 request to exercise the right until the consumer provides
17 additional information reasonably necessary to authenticate
18 the consumer and the consumer's request to exercise the
19 right. A controller shall not be required to authenticate an
20 opt-out request under subsection (a)(5), but the controller
21 may deny an opt-out request if the controller has a good
22 faith, reasonable and documented belief that the request is
23 fraudulent. If a controller denies an opt-out request under
24 subsection (a)(5) because the controller believes the request
25 is fraudulent, the controller shall send a notice to the
26 person who made the request disclosing that the controller
27 believes the request is fraudulent, why the controller
28 believes the request is fraudulent and that the controller
29 will not comply with the request.

30 (5) A controller that has obtained personal data about a

1 consumer from a source other than the consumer shall be
2 deemed in compliance with a consumer's request to delete the
3 personal data in accordance with subsection (a)(3) by
4 retaining a record of the deletion request and the minimum
5 data necessary for the purpose of ensuring that the
6 consumer's personal data remains deleted from the
7 controller's records and not using such retained data for any
8 other purpose in accordance with the provisions of this act
9 or opting the consumer out of the processing of the data for
10 any purpose except for those exempted under section 11(a)(3).

11 (d) Appeals.--A controller shall establish a process for a
12 consumer to appeal the controller's refusal to take action on a
13 request by a consumer to exercise the consumer's rights under
14 subsection (a) within a reasonable period of time after the
15 consumer's receipt of the decision under subsection (c)(2). The
16 appeal process shall be conspicuously available and similar to
17 the process for submitting requests to initiate an action under
18 subsection (b). No later than 60 days after receipt of an
19 appeal, the controller shall inform the consumer in writing of
20 an action taken or not taken in response to the appeal,
21 including a written explanation of the reason for the decision.
22 If the appeal is denied, the controller shall also provide the
23 consumer with an online mechanism, if available, or other method
24 through which the consumer may contact the Attorney General to
25 submit a complaint.

26 Section 4. Designation of authorized agent.

27 A consumer may designate another person to serve as the
28 consumer's authorized agent and act on the consumer's behalf to
29 opt out of the processing of the consumer's personal data for
30 the purposes specified under section 3(a)(5). A controller shall

1 comply with an opt-out request received from an authorized agent
2 under section 3(a)(5) if the controller is able to verify, with
3 commercially reasonable effort, the identity of the consumer and
4 the authorized agent's authority to act on the consumer's
5 behalf.

6 Section 5. Duties of controllers.

7 (a) Duties.--A controller shall have all of the following
8 duties:

9 (1) Limit the collection of personal data to what is
10 adequate, relevant and reasonably necessary in relation to
11 the purposes for which the data is processed, as disclosed to
12 the consumer.

13 (2) Except as otherwise provided in this act, refrain
14 from processing personal data for purposes that are neither
15 reasonably necessary to, nor compatible with, the disclosed
16 purposes for which the personal data is processed, as
17 disclosed to the consumer, unless the controller obtains the
18 consumer's consent.

19 (3) Process personal data in a manner that ensures
20 reasonable and appropriate administrative, technical,
21 organizational and physical safeguards of personal data
22 collected, stored and processed.

23 (4) Refrain from processing sensitive data concerning a
24 consumer without obtaining the consumer's consent or, in the
25 case of the processing of sensitive data concerning a known
26 child, without processing the data, in accordance with 15
27 U.S.C. Ch. 91 (relating to children's online privacy
28 protection).

29 (5) Refrain from processing personal data in violation
30 of a Federal or State law that prohibits unlawful

1 discrimination against a consumer.

2 (6) Provide an effective mechanism for a consumer to
3 revoke the consumer's consent that is at least as easy as the
4 mechanism by which the consumer provided the consumer's
5 consent and, upon revocation of the consent, cease to process
6 the data as soon as practicable, but no later than 15 days
7 after the receipt of the request.

8 (7) Refrain from processing the personal data of a
9 consumer for the purpose of targeted advertising or selling
10 the consumer's personal data without the consumer's consent
11 under circumstances where the controller has actual knowledge
12 and willfully disregards that the consumer is younger than 16
13 years of age.

14 (8) Refrain from discriminating against a consumer for
15 exercising any of the consumer rights under section 3(a),
16 including denying goods or services, charging different
17 prices or rates for goods or services or providing a
18 different level of quality of goods or services to the
19 consumer.

20 (b) Construction.--Nothing in subsection (a) shall be
21 construed to require a controller to provide a product or
22 service that requires the personal data of a consumer that the
23 controller does not collect or maintain nor prohibit a
24 controller from offering a different price, rate, level, quality
25 or selection of goods or services to a consumer, including
26 offering goods or services for no fee, if the offering is in
27 connection with a consumer's voluntary participation in a bona
28 fide loyalty, rewards, premium features, discounts or club card
29 program.

30 (c) Privacy notice.--A controller shall provide a consumer

1 with a reasonably accessible, clear and meaningful privacy
2 notice that includes all of the following:

3 (1) The categories of personal data processed by the
4 controller.

5 (2) The purpose for processing personal data.

6 (3) How the consumer may exercise the consumer's rights,
7 including how the consumer may appeal the controller's
8 decision with regard to the consumer's request under section
9 3(d).

10 (4) The categories of personal data that the controller
11 shares with each third party.

12 (5) The categories of each third party with which the
13 controller shares personal data.

14 (6) An active email address or other online mechanism
15 that the consumer may use to contact the controller.

16 (d) Disclosures.--If a controller sells personal data to a
17 third party or processes personal data for targeted advertising,
18 the controller shall clearly and conspicuously disclose the sale
19 or processing and the manner in which a consumer may exercise
20 the right to opt out of the sale or processing.

21 (e) Means to exercise rights.--

22 (1) A controller shall establish and describe in the
23 privacy notice under subsection (c) a secure and reliable
24 means for consumers to submit a request to exercise the
25 consumer's rights under section 3(a). The secure and reliable
26 means under this paragraph shall take into account the manner
27 in which a consumer normally interacts with the controller,
28 the need for secure and reliable communication for the
29 request and the ability of the controller to verify the
30 identity of the consumer making the request. A controller may

1 not require a consumer to create a new account in order to
2 exercise the consumer's rights under section 3(a), but may
3 require the consumer to use an existing account. The secure
4 and reliable means shall include all of the following:

5 (i) Providing a clear and conspicuous link on the
6 controller's Internet website to an Internet web page
7 that enables a consumer, or an agent of the consumer, to
8 opt out of the targeted advertising or sale of the
9 consumer's personal data under section 3(a)(5).

10 (ii) No later than January 1 of the year commencing
11 two years after the effective date of this subparagraph,
12 allowing a consumer to opt out of the processing of the
13 consumer's personal data for the purpose of targeted
14 advertising or the sale of the consumer's personal data
15 under section 3(a)(5) through an opt-out preference
16 signal sent, with the consumer's consent, by a platform,
17 technology or mechanism to the controller indicating the
18 consumer's intent to opt out of the processing or sale.
19 The platform, technology or mechanism shall comply with
20 all of the following criteria:

21 (A) Not unfairly disadvantage another
22 controller.

23 (B) Not make use of a default setting, but
24 instead require the consumer to make an affirmative,
25 freely given and unambiguous choice to opt out of the
26 processing or sale of the consumer's personal data.

27 (C) Be consumer friendly and easy to use by the
28 average consumer.

29 (D) Be as consistent as possible with any other
30 similar platform, technology or mechanism required by

1 a Federal or State law or regulation.

2 (E) Enable the controller to accurately
3 determine whether the consumer is a resident of this
4 Commonwealth and whether the consumer has made a
5 legitimate request to opt out of processing or sale
6 of the consumer's personal data.

7 (F) Be in compliance with this section. A
8 controller that recognizes signals approved by other
9 states shall be considered in compliance with this
10 section.

11 (iii) If a consumer's decision to opt out of the
12 processing of the consumer's personal data for the
13 purpose of targeted advertising or the sale of the
14 consumer's personal data under section 3(a)(5) through an
15 opt-out preference signal sent under subparagraph (ii)
16 conflicts with the consumer's existing controller-
17 specific privacy setting or voluntary participation in a
18 controller's bona fide loyalty, rewards, premium
19 features, discounts or club card program, the controller
20 shall comply with the consumer's opt-out preference
21 signal, but may notify the consumer of the conflict and
22 provide to the consumer the choice to confirm the
23 controller-specific privacy setting or participation in
24 the program.

25 (2) If a controller responds to a consumer's opt-out
26 request under paragraph (1)(i) by informing the consumer of a
27 charge for the use of a product or service, the controller
28 shall present the terms of a bona fide loyalty, rewards,
29 premium features, discounts or club card program for the
30 retention, use, sale or sharing of the consumer's personal

1 data.

2 Section 6. Duties of processors.

3 (a) Assistance.--A processor shall adhere to the
4 instructions of a controller and shall assist the controller in
5 complying with the controller's duties under this act. The
6 assistance shall include all of the following:

7 (1) Taking into account the nature of processing and the
8 information available to the processor, by appropriate
9 technical and organizational measures, insofar as is
10 reasonably practicable, to fulfill the controller's duty to
11 comply with a request by a consumer to exercise the
12 consumer's rights under section 3(a).

13 (2) Taking into account the nature of processing and the
14 information available to the processor, by assisting the
15 controller in meeting the controller's duties in relation to
16 the security of processing the personal data and in relation
17 to the notification of a breach of security of the system of
18 the processor.

19 (3) Providing necessary information to enable the
20 controller to conduct and document data protection
21 assessments.

22 (b) Contracts.--A contract between a controller and a
23 processor shall govern the processor's data processing
24 procedures with respect to processing performed on behalf of the
25 controller. The contract shall be binding and clearly state the
26 instructions for processing data, the nature and purpose of
27 processing, the type of data subject to processing, the duration
28 of processing and the rights and obligations of both parties.
29 The contract shall also require that the processor comply with
30 all of the following:

1 (1) Ensure that each person processing personal data is
2 subject to a duty of confidentiality with respect to the
3 data.

4 (2) At the controller's direction, delete or return all
5 personal data to the controller as requested at the end of
6 the provision of services, unless retention of the personal
7 data is required by Federal or State law.

8 (3) Upon the reasonable request of the controller, make
9 available to the controller all information in the
10 processor's possession necessary to demonstrate the
11 processor's compliance with the provisions of this act.

12 (4) After providing the controller with an opportunity
13 to object, engage a subcontractor pursuant to a written
14 contract that requires the subcontractor to meet the
15 obligations of the processor with respect to the personal
16 data.

17 (5) Allow and cooperate with a reasonable assessment by
18 the controller or the controller's designated assessor, or
19 arrange for a qualified and independent assessor to conduct
20 an assessment of the processor's policies and technical and
21 organizational measures in support of the requirements under
22 this act, using an appropriate and accepted control standard
23 or framework and assessment procedure for the assessment. The
24 processor shall provide a report of the assessment to the
25 controller upon request.

26 (c) Construction.--Nothing in this section shall be
27 construed to relieve a controller or processor from the
28 liabilities imposed on the controller or processor by virtue of
29 the role of the controller or processor in the processing
30 relationship specified under this act.

(d) Acting as controller or processor.--A determination of whether a person is acting as a controller or processor with respect to a specific processing of data shall be a fact-based determination that depends upon the context in which personal data is to be processed. The following shall apply:

(1) A person who is not limited in the person's processing of personal data pursuant to a controller's instructions or who fails to adhere to the instructions shall be a controller and not a processor with respect to a specific processing of data.

(2) A processor who continues to adhere to a controller's instructions with respect to a specific processing of personal data shall remain a processor.

(3) If a processor begins, alone or jointly with others, determining the purposes and means of the processing of personal data, the processor shall be a controller with respect to the processing and may be subject to an enforcement action under section 10.

Section 7. Data protection assessment.

(a) Assessment.--A controller shall conduct and document a data protection assessment for each of the controller's processing activities that present a heightened risk of harm to a consumer.

(b) Benefits and risks.--In conducting a data protection assessment under subsection (a), a controller shall identify and weigh the benefits that may flow, directly and indirectly, from the processing to the controller, the consumer, other stakeholders and the public against the potential risks to the consumer's rights under section 3(a) associated with the processing, as mitigated by safeguards that can be employed by

1 the controller to reduce the risks. The controller shall factor
2 all of the following into the data protection assessment:

3 (1) The use of de-identified data.

4 (2) The reasonable expectations of the consumer.

5 (3) The context of the processing and the relationship
6 between the controller and the consumer whose personal data
7 will be processed.

8 (c) Availability of assessments.--The Attorney General may
9 require a controller to disclose a data protection assessment
10 under subsection (a) that is relevant to an investigation
11 conducted by the Attorney General, and the controller shall make
12 the data protection assessment available to the Attorney
13 General. The Attorney General may evaluate a data protection
14 assessment for compliance with the provisions of this act. A
15 data protection assessment shall be confidential and exempt from
16 disclosure under 5 U.S.C. § 552 (relating to public information;
17 agency rules, opinions, orders, records, and proceedings) and
18 the act of February 14, 2008 (P.L.6, No.3), known as the Right-
19 to-Know Law. To the extent that information contained in a data
20 protection assessment disclosed to the Attorney General under
21 this subsection includes information subject to attorney-client
22 privilege or work product protection, the disclosure shall not
23 constitute a waiver of the privilege or protection.

24 (d) Comparison of processing operations.--A single data
25 protection assessment under subsection (a) may address a
26 comparable set of processing operations that includes similar
27 activities.

28 (e) Compliance.--If a controller conducts a data protection
29 assessment for the purpose of complying with another applicable
30 Federal or State law or regulation, the data protection

1 assessment shall be deemed to satisfy the requirements under
2 this section if the data protection assessment is reasonably
3 similar in scope and effect to the data protection assessment
4 that would otherwise be conducted under this section.

5 (f) Applicability.--The data protection assessment
6 requirements under this section shall apply to processing
7 activities created or generated after July 1 of the year
8 commencing one year after the effective date of this subsection
9 and shall not apply retroactively.

10 Section 8. De-identified data and pseudonymous data.

11 (a) Duties.--A controller in possession of de-identified
12 data shall have the following duties:

13 (1) Take reasonable measures to ensure that the de-
14 identified data cannot be associated with an individual.

15 (2) Publicly commit to maintaining and using de-
16 identified data without attempting to re-identify the data.

17 (3) Contractually obligate a recipient of the de-
18 identified data to comply with the provisions of this act.

19 (b) Construction.--Nothing in this act shall be construed to
20 require a controller or processor to:

21 (1) require a controller or processor to re-identify de-
22 identified data or pseudonymous data;

23 (2) maintain data in identifiable form or collect,
24 obtain, retain or access data or technology in order to be
25 capable of associating an authenticated consumer rights
26 request under section 3(a); or

27 (3) comply with an authenticated consumer rights request
28 under section 3(a) if the controller:

29 (i) is not reasonably capable of associating the
30 request with the personal data, or it would be

unreasonably burdensome for the controller to associate the request with the consumer's personal data;

(ii) does not use the personal data to recognize or respond to the specific consumer who is the subject of the personal data or does not associate the personal data with other personal data about the same specific consumer; and

(iii) does not sell the personal data to a third party or otherwise voluntarily disclose the personal data to a third party other than a processor, except as authorized under this section.

(c) Pseudonymous data.--The consumer rights specified under section 3(a)(1), (2), (3) or (4) shall not apply to pseudonymous data if a controller is able to demonstrate that any information necessary to identify the consumer is kept separately and is subject to effective technical and organizational controls that prevent the controller from accessing the information.

(d) Oversight.--A controller that discloses pseudonymous data or de-identified data shall exercise reasonable oversight to monitor compliance with a contractual commitment to which the pseudonymous data or de-identified data is subject and shall take appropriate steps to address a breach of the contractual commitment.

Section 9. Exemptions on restrictions for controllers or processors.

(a) Legal compliance.--Nothing in this act shall be construed to restrict the ability of a controller or processor to:

- (1) comply with Federal or State laws or local ordinances or regulations;

1 (2) comply with a civil, criminal or regulatory inquiry,
2 investigation, subpoena or summons by a Federal, State,
3 municipal or other governmental authority;

4 (3) cooperate with a law enforcement agency concerning a
5 conduct or activity that the controller or processor
6 reasonably and in good faith believes may violate a Federal
7 or State law or local ordinance or regulation;

8 (4) investigate, establish, exercise, prepare for or
9 defend legal claims;

10 (5) provide a product or service specifically requested
11 by a consumer;

12 (6) perform under a contract to which a consumer is a
13 party, including fulfilling the terms of a written warranty;

14 (7) take steps at the request of a consumer prior to
15 entering into a contract;

16 (8) take immediate steps to protect an interest that is
17 essential for the life or physical safety of a consumer or
18 another individual, including when processing cannot be
19 manifestly based on the provisions of this act;

20 (9) prevent, detect, protect against or respond to a
21 security incident, identity theft, fraud, harassment,
22 malicious or deceptive activity or illegal activity, preserve
23 the integrity or security of a system or investigate, report
24 or prosecute an individual responsible for an incident
25 specified under this paragraph;

26 (10) engage in public or peer-reviewed scientific or
27 statistical research in the public interest that adheres to
28 all other applicable Federal or State ethics and privacy laws
29 and is approved, monitored and governed by an institutional
30 review board or a similar independent oversight entity that

determines whether:

(i) the deletion of information is likely to provide substantial benefits to the research that do not exclusively accrue to the controller;

(ii) the expected benefits of the research outweigh the privacy risks; and

(iii) the controller has implemented reasonable safeguards to mitigate privacy risks associated with the research, including risks associated with re-identification;

(11) assist another controller, processor or third party with any of the requirements under this act; or

(12) process personal data for reasons of public interest in the area of public health, community health or population health, but solely to the extent that the processing is:

(i) subject to suitable and specific measures to safeguard the rights of the consumer whose personal data is being processed; and

(ii) under the responsibility of a professional subject to confidentiality obligations under Federal or State law or local ordinance.

(b) Data collection.--The requirements imposed on a controller or processor under this act shall not restrict the ability of a controller or processor to collect, use or retain data for internal use for any of the following purposes:

(1) Conducting internal research to develop, improve or repair products, services or technology.

(2) Effectuating a product recall.

(3) Identifying and repairing technical errors that

1 impair existing or intended functionality.

2 (4) Internal operations that are reasonably aligned with
3 the expectations of a consumer or reasonably anticipated
4 based on the consumer's existing relationship with the
5 controller or are otherwise compatible with processing data
6 in furtherance of the provision of a product or service
7 specifically requested by a consumer.

8 (c) Evidentiary privilege.--The requirements imposed on a
9 controller or processor under this act shall not apply if
10 compliance by the controller or processor with requirements
11 would violate an evidentiary privilege under the laws of this
12 Commonwealth. Nothing in this act shall be construed to prevent
13 a controller or processor from providing personal data
14 concerning a consumer to an individual covered by an evidentiary
15 privilege under the laws of this Commonwealth as part of a
16 privileged communication.

17 (d) Third parties.--A controller or processor that discloses
18 personal data to a third-party controller or third-party
19 processor in accordance with this act shall not be deemed to
20 have violated the provisions of this act if the third-party
21 controller or third-party processor violates the provisions of
22 this act if, at the time of the disclosure, the disclosing
23 controller or processor did not have actual knowledge that the
24 third-party controller or third-party processor would violate
25 the provisions of this act. A third-party controller or third-
26 party processor who receives personal data under this subsection
27 in accordance with this act shall not be deemed to have violated
28 the provisions of this act for a violation by the disclosing
29 controller or processor.

30 (e) Individual liberties.--Nothing in this act shall be

1 construed to:

2 (1) impose an obligation on a controller or processor
3 that adversely affects the rights or freedoms of an
4 individual, including the freedom of speech or freedom of the
5 press guaranteed in the First Amendment to the Constitution
6 of the United States or section 7 of Article I of the
7 Constitution of Pennsylvania; or

8 (2) apply to an individual's processing of personal data
9 in the course of the individual's purely personal or
10 household activities.

11 (f) Personal data.--

12 (1) Personal data processed by a controller may be
13 processed to the extent that the processing meets all of the
14 following criteria:

15 (i) Is reasonably necessary and proportionate to the
16 purposes specified under this section.

17 (ii) Is adequate, relevant and limited to what is
18 necessary in relation to the specific purposes specified
19 under this section.

20 (2) A controller or processor that collects, uses or
21 retains personal data under subsection (b) shall, when
22 applicable, take into account the nature and purpose of the
23 collection, use or retention of the personal data. The
24 personal data under subsection (b) shall be subject to
25 reasonable administrative, technical and physical measures to
26 protect the confidentiality, integrity and accessibility of
27 the personal data and reduce reasonably foreseeable risks of
28 harm to a consumer related to the collection, use or
29 retention of the personal data.

30 (g) Exemptions.--If a controller processes personal data in

1 accordance with an exemption under this section, the controller
2 shall be responsible for demonstrating that the processing
3 qualifies for the exemption and complies with the requirements
4 under subsection (f).

5 (h) Legal entities.--The processing of personal data for the
6 purposes expressly specified under this section shall not solely
7 make a legal entity a controller with respect to the processing.
8 Section 10. Penalties, enforcement and private rights of
9 action.

10 (a) Enforcement.--The Attorney General shall have exclusive
11 authority to enforce the provisions of this act. The following
12 shall apply:

13 (1) During the period beginning January 1 and ending
14 July 1 of the year commencing one year after the effective
15 date of this paragraph, the Attorney General shall, prior to
16 initiating an action for a violation of a provision of this
17 act, issue a notice of violation to the controller or
18 processor if the Attorney General determines that a cure is
19 possible. If the controller fails to cure the violation
20 within 60 days of receipt of the notice of violation, the
21 Attorney General may initiate an action under this section.

22 (2) Beginning January 1 of the year commencing one year
23 after the effective date of this paragraph, the Attorney
24 General may, in determining whether to grant a controller or
25 processor the opportunity to cure an alleged violation under
26 paragraph (1), consider all of the following:

27 (i) The number of violations.

28 (ii) The size and complexity of the controller or
29 processor.

30 (iii) The nature and extent of the processing

activities of the controller or processor.

(iv) The substantial likelihood of injury to the public.

(v) The safety of persons or property.

(vi) Whether the alleged violation was likely caused by human or technical error.

(3) The right to cure shall apply for 60 days.

(b) Private rights of action.--Nothing in this act shall be construed as providing the basis for a private right of action for a violation of the provisions of this act.

(c) Unfair trade practice.--Violations of the provisions of this act shall constitute "unfair methods of competition" and "unfair or deceptive acts or practices" under the act of December 17, 1968 (P.L.1224, No.387), known as the Unfair Trade Practices and Consumer Protection Law, and shall be enforced exclusively by the Attorney General.

(d) Regulations.--The Attorney General shall promulgate regulations necessary to implement this section.

Section 11. Nonapplicability, exemption and consent.

(a) Nonapplicability.--This act shall not apply to any of the following:

(1) The Commonwealth or any of its political subdivisions.

(2) A nonprofit organization.

(3) An institution of higher education.

(4) A national securities association that is registered under 15 U.S.C. § 78o-3 (relating to registered securities associations).

(5) A financial institution or an affiliate of a financial institution or data subject to Title V of the

Gramm-Leach-Bliley Act (15 U.S.C. § 6801 et seq.).

(6) A covered entity or business associate.

(b) Exemptions.--The following shall be exempt from the provisions of this act:

(1) Protected health information under HIPAA.

(2) Patient-identifying information for purposes of 42 U.S.C. § 290dd-2 (relating to confidentiality of records).

(3) Identifiable private information for purposes of the Federal policy for the protection of human subjects under 45 CFR Subt. A Subch. A Pt. 46 (relating to protection of human subjects).

(4) Identifiable private information that is otherwise information collected as part of human subjects research in accordance with the good clinical practice guidelines issued by the International Council for Harmonisation of Technical Requirements for Pharmaceuticals for Human Use on the effective date of this paragraph.

(5) The protection of human subjects under 21 CFR Ch. I Subch. A Pt. 50 (relating to protection of human subjects) or 56 (relating to institutional review boards) or personal data used or shared in research, as defined in 45 CFR 164.501 (relating to definitions), that is conducted in accordance with the standards specified under this subsection or other research conducted in accordance with applicable Federal or State law.

(6) Information and documents created for the purposes of 42 U.S.C. Ch. 117 (relating to encouraging good faith professional review activities).

(7) Patient safety work product for the purposes of 42 U.S.C. Ch. 6A Subch. VII Pt. C (relating to patient safety

improvement).

(8) Information derived from any of the health-care-related information exempt under this subsection that is de-identified in accordance with the requirements for de-identification under HIPAA.

(9) Information originating from and intermingled to be indistinguishable with, or information treated in the same manner as, information exempt under this subsection that is maintained by a covered entity or business associate, program or qualified service organization as specified in 42 U.S.C. § 290dd-2.

(10) Information used for public health activities and purposes as authorized by HIPAA, community health activities and population health activities.

(11) The collection, maintenance, disclosure, sale, communication or use of personal information bearing on a consumer's credit worthiness, credit standing, credit capacity, character, general reputation, personal characteristics or mode of living by a consumer reporting agency, furnisher or user that provides information for use in a consumer report or by a user of a consumer report, but only to the extent that the activity is regulated by and authorized under 15 U.S.C. Ch. 41 Subch. III (relating to credit reporting agencies).

(12) Personal data collected, processed, sold or disclosed in compliance with 18 U.S.C. Ch. 123 (relating to prohibition on release and use of certain personal information from state motor vehicle records).

(13) Personal data regulated by 20 U.S.C. Ch. 31 Subch. III Pt. 4 (relating to records; privacy; limitation on

1 withholding Federal funds).

2 (14) Personal data collected, processed, sold or
3 disclosed in compliance with 12 U.S.C. Ch. 23 (relating to
4 farm credit system).

5 (15) Data processed or maintained:

6 (i) in the course of an individual applying to,
7 employed by or acting as an agent or independent
8 contractor of a controller, processor or third party to
9 the extent that the data is collected and used within the
10 context of that role;

11 (ii) as the emergency contact information of an
12 individual specified under this act and used for
13 emergency contact purposes; or

14 (iii) as necessary to administer benefits for
15 another individual related to an individual who is the
16 subject of the information under paragraph (1) and used
17 for the purposes of administering the benefits.

18 (16) Personal data collected, processed, sold or
19 disclosed in relation to price, route or service by an air
20 carrier under 49 U.S.C. Subt. VII Pt. A. Subpt. I Ch. 401
21 (relating to general provisions) to the extent preempted
22 under 49 U.S.C. § 41713 (relating to preemption of authority
23 over prices, routes, and service).

24 (c) Parental consent.--A controller or processor that
25 complies with the verifiable parental consent requirements under
26 15 U.S.C. Ch. 91 (relating to children's online privacy
27 protection) shall be deemed compliant with an obligation to
28 obtain parental consent under this act.

29 Section 12. Effective date.

30 This act shall take effect in one year.